



Cundinamarca Emprende

Datos generales del proyecto

Campo	Descripción
Nombre del proyecto:	(Ej. Sistema de Gestión de Inventarios)
Repositorio:	https://gitlab.com/gcun/camino-c/
Versión / Build:	(v1.2.3 o número de compilación)
Fecha de análisis:	(11/11/2025)
Analista / Responsable:	Nelson Alfredo Casas Sanabria equipo Transformación Digital
Herramienta:	SonarQube (versión v25.10.0.114319)
Fuente del análisis:	sonar.token=sqp_c0f2a6493afb21a750bbeb7ea7ac428331f3a19e

Resumen ejecutivo

Sistema de gestión para emprendimientos de Cundinamarca, desarrollado con SolidJS y Redmine como backend.

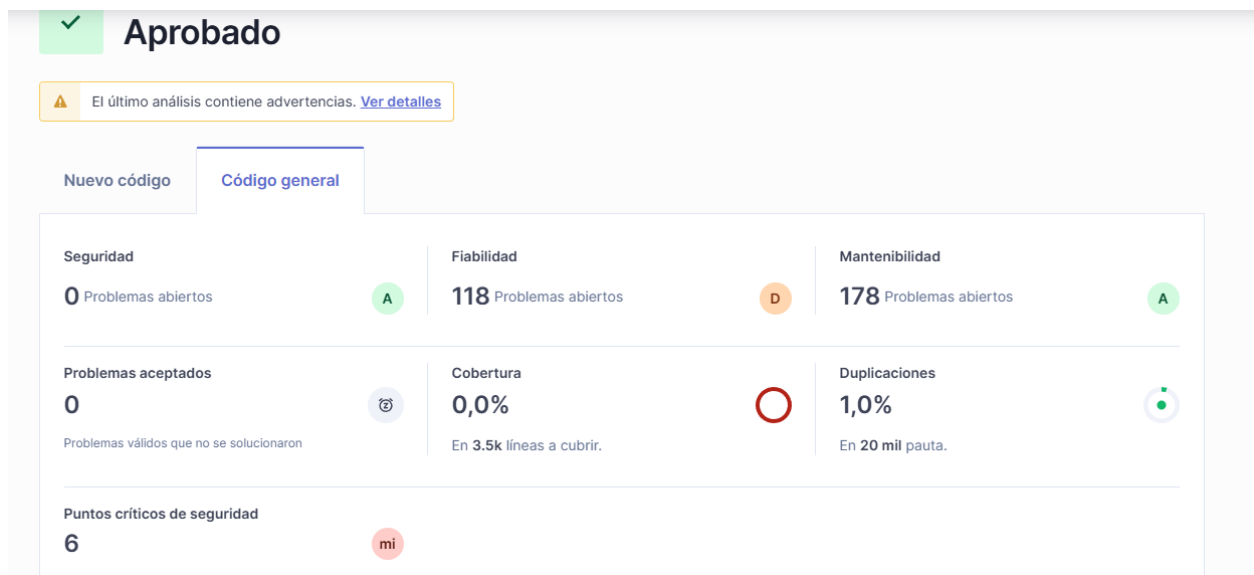


Figura 1-Descripción general





Este proyecto es una plataforma web para la gestión de emprendimientos en Cundinamarca. Permite a los usuarios registrar información sobre sus emprendimientos, realizar diagnósticos, y visualizar estadísticas a través de dashboards interactivos.

Características Principales

- **Formulario de Registro:** Formulario completo para registro de emprendimientos con validación
- **Dashboard Interactivo:** Visualización de estadísticas y métricas de emprendimientos
- **Sistema de Diagnóstico:** Evaluación y diagnóstico de emprendimientos
- **Autenticación:** Integración con Redmine OAuth para autenticación
- **Gestión de Emprendimientos:** CRUD completo de emprendimientos

Infraestructura

Docker: Containerización

Docker Compose: Orquestación de contenedores

Nginx: Servidor web y reverse proxy

Recomendaciones

Se han detectado archivos con problemas de **codificación de caracteres** (encoding) en el código fuente.

Esto puede deberse a que algunos archivos están en formatos distintos, como ANSI, ISO-8859-1, o UTF-16, mientras otros usan UTF-8.

Esta inconsistencia puede provocar errores al compilar, ejecutar, o desplegar la aplicación, especialmente en entornos con diferente configuración regional o sistema operativo.

Todos los archivos del código fuente deben estar en formato **UTF-8 sin BOM**, garantizando la compatibilidad entre plataformas y evitando errores de interpretación de texto o caracteres especiales.





Usa imágenes oficiales o de fuentes confiables.

Evita descargar imágenes de Docker Hub sin verificar su procedencia.

Verifica la integridad y firma de las imágenes.

Usa docker trust inspect o implementa **Docker Content Trust (DCT)** para firmar y validar imágenes.

Mantén las imágenes actualizadas.

Rebuild y actualiza imágenes cuando haya parches de seguridad del sistema base o librerías.

Usa imágenes mínimas.

Prefiere bases como alpine, scratch o distroless para reducir la superficie de ataque.

Fuente

[camino-c/frontend/src/services/formService.ts](#)

Donde esta el riesgo

```
146     nulo
147   };
148
149   // Funciones de validación
150   constante validarRequerido= (valor: cadena): cadena | nulo =>{
151     devolver;valor.recortar() ?"Este campo es requerido": nulo;
152   };
153
154   constante validar correo electrónico= (valor: cadena): cadena | nulo =>{
155     si(!valor.recortar())devolver "Este campo es requerido";
156     constante Expresión regular de correo electrónico=/^[^\\s@]+@^[^\\s@]+\\.^[^\\s@]+$/;
157
158     devolver;Expresión regular de correo electrónico.prueba(valor)
159       ? "Ingrese un correo electrónico válido"
160       : nulo;
161   };
```

Asegúrese de que la expresión regular utilizada aquí, que es vulnerable a un tiempo de ejecución superlineal debido al retroceso, no pueda provocar una denegación de servicio.

Cual es el Riesgo?

La mayoría de los motores de expresiones regulares utilizan retroceso para probar todas las posibles rutas de ejecución al evaluar una entrada. En algunos casos, esto puede provocar problemas de rendimiento, conocidos como retrocesos catastróficos . En el peor de los casos, la complejidad de la expresión regular crece exponencialmente con el tamaño de la entrada. Esto significa que una entrada pequeña y cuidadosamente elaborada (como 20 caracteres) puede desencadenar un retroceso catastrófico y provocar una denegación de servicio de la aplicación.





Una complejidad superlineal de la expresión regular también puede tener el mismo impacto, en este caso, con una entrada grande y cuidadosamente elaborada (miles de caracteres).

Esta regla determina la complejidad temporal de una expresión regular y le informa si no es lineal.

Pregúntate si

La entrada está controlada por el usuario.

El tamaño de entrada no está restringido a un pequeño número de caracteres.

No existe ningún límite de tiempo establecido para la evaluación de expresiones regulares.

Existe un riesgo si respondió afirmativamente a cualquiera de esas preguntas.

Prácticas de codificación segura recomendadas

Para evitar situaciones catastróficas de retroceso, asegúrese de que ninguna de las siguientes condiciones se aplique a su expresión regular.

En todos los casos siguientes, el retroceso catastrófico solo puede ocurrir si la parte problemática de la expresión regular es seguida por un patrón que puede fallar, lo que provoca que el retroceso ocurra realmente.

Si se tiene una repetición r^* o $r^+?$ una cadena, de modo que la expresión regular pueda producir diferentes coincidencias posibles (de longitudes posiblemente distintas) con la misma entrada, el tiempo de coincidencia en el peor de los casos puede ser exponencial. Esto puede ocurrir si la cadena r contiene partes opcionales, alternancias o repeticiones adicionales (pero no si la repetición está escrita de forma que solo haya una manera de encontrarla).

Prácticas de codificación segura recomendadas

Para evitar situaciones catastróficas de retroceso, asegúrese de que ninguna de las siguientes condiciones se aplique a su expresión regular.

En todos los casos siguientes, el retroceso catastrófico solo puede ocurrir si la parte problemática de la expresión regular es seguida por un patrón que puede fallar, lo que provoca que el retroceso ocurra realmente.

- Si se tiene una repetición r^* o $r^+?$ una cadena, de modo que la expresión regular pueda producir diferentes coincidencias posibles (de longitudes posiblemente distintas) con la misma entrada, el tiempo de coincidencia en el peor de los casos puede ser exponencial. Esto puede ocurrir si la cadena r contiene partes opcionales, alternancias o repeticiones adicionales (pero no si la repetición está escrita de forma que solo haya una manera de encontrarla).





Ver

- OWASP - [Top 10 2017 Categoría A1 - Inyección](#)
- CWE - [CWE-400 - Consumo incontrolado de recursos](#)
- CWE - [CWE-1333 - Complejidad ineficiente de expresiones regulares](#)
- [owasp.org](#) - Denegación de servicio por expresiones regulares de OWASP - ReDoS
- [stackstatus.net \(archivo\)](#) - Análisis posterior a la interrupción del servicio - 20 de julio de 2016
- [regular-expressions.info](#) - Expresiones regulares descontroladas: retroceso catastrófico
- [docs.microsoft.com](#) - Retroceso con cuantificadores opcionales anidados

camino-c/backend/Dockerfile

```
1  FROM redmine:6-alpine
2
3  CORREapk add --no-cache git build-base
4  CMD["rails", "servidor", "-b", "0.0.0.0"]
```

La imagen "redmine" se ejecuta con "root" como usuario predeterminado. Asegúrese de que esto sea seguro.

Solución compatible

Para imágenes basadas en Linux e imágenes basadas en scratch que descomprimen una distribución de Linux:

DESDE los Alpes

EJECUTAR `addgroup -S nonroot \`
`&& adduser -S no raíz -G no raíz`

USUARIO sin privilegios de administrador

PUNTO DE ENTRADA ["id"]

Para imágenes basadas en Windows, puede usar ContainerUser para crear un nuevo usuario:
DE `mcr.microsoft.com/windows/servercore:ltsc2019`

Ejecutar `net user /add nonroot`





USUARIO sin privilegios
de administrador

Para compilaciones en varias etapas, el usuario sin privilegios de administrador debe estar en la última etapa:

FROM alpine as builder

COPY Makefile ./src /

RUN make build

FROM alpine as runtime

RUN addgroup -S nonroot \

&& adduser -S nonroot -G nonroot

COPY --from=builder bin/production /app

USER nonroot

ENTRYPOINT ["/app/production"]

```
9      CORRERnpm run build
10
11      CORRERecho "Contenido de /usr/src/app/dist/ :" && ls -la /usr/src/app/dist/cundinamarca-emprende
12
13      # Etapa 2: Servir la aplicación usando Nginx
14      DENGINX:alpine
15
16      COPIAR--from=build /usr/src/app/dist/cundinamarca-emprende /usr/share/nginx/html
17      COPIARnginx.conf /etc/nginx/conf.d/default.conf
18      EXPONER80
19      CMD["nginx" "-g" "daemon off;"]
```

La imagen "nginx" se ejecuta con "root" como usuario predeterminado. Asegúrese de que esto sea seguro.

Figura 2- La imagen "nginx" se ejecuta con "root" como usuario predeterminado. Asegúrese de que esto sea seguro.

```
4      ARGURL_API_BACKEND_VITE
5      ENVURL_API_VITE_BACKEND=${URL_API_VITE_BACKEND}
6      COPIARpaquete*.json ./
7      CORRERnpm install
8      COPIAR.
9
10     CORRERnpm run build
11
12     CORRERecho "Contenido de /usr/src/app/dist/ :" && ls -la /usr/src/app/dist/cundinamarca-emprende
```

Copiar de forma recursiva podría añadir inadvertidamente datos confidenciales al contenedor. Asegúrese de que sea seguro hacerlo aquí.

Figura 3 -Copiar de forma recursiva podría añadir inadvertidamente datos confidenciales al contenedor. Asegúrese de que sea seguro hacerlo aquí.



Ver

- CWE - [CWE-284 - Control de acceso inadecuado](#)
- [nginxinc/nginx-unprivileged: Ejemplo de un contenedor sin privilegios de administrador por defecto](#)
- [Documentación de Microsoft: Cuándo usar las cuentas de usuario ContainerAdmin y ContainerUser](#)

```

4
5 exportar por defecto definirConfiguración({
6   complementos: [Complemento sólido(), viento de cola css()],
7   directorio público: "src/public",
8   servidor: {
9     puerto: 3000,
10    apoderado: {
11      "/api": {
12        objetivo: "http://172.20.6.167:7081",
13
14        seguro: falso,
15        cambioOrigen: verdadero,
16        reescribir: (camino) => camino.reemplazar(/^\/api/, ""),
17      },
18    },
19    construir: {
20      objetivo: "esnext",

```

Figura 4-El uso del protocolo HTTP es inseguro. Utilice HTTPS en su lugar.

```
3 DIRECCIÓN DE TRABAJO /usr/src/app
4 ARGURL_API_BACKEND_VITE
5 ENVURL_API_VITE_BACKEND=${URL_API_VITE_BACKEND}
6 COPIARpaquete*.json ./
7 CORRER npm install
```

Omitir "--ignore-scripts" puede provocar la ejecución de scripts de shell. Asegúrese de que esto sea seguro.

```
8 COPIAR.
9 CORRERNpm run build
10
11 CORRERecho "Contenido de /usr/src/app/dist/ :" && ls -la /usr/src/app/dist/cundinamarca-emprende
12
```

Figura 5 Omitir "--ignore-scripts" puede provocar la ejecución de scripts de shell. Asegúrese de que esto sea seguro.



Calidad de Software

La calidad de software es el conjunto de características que garantizan que un sistema cumple con los requisitos funcionales y no funcionales, ofreciendo confiabilidad, seguridad, eficiencia y facilidad de mantenimiento.

En otras palabras, un software de calidad funciona bien, es seguro, fácil de usar y de mejorar con el tiempo.

camino-c > camino-c

Seleccionar archivos Navegar por

	Líneas de código	Seguridad	Fiabilidad	Mantenibilidad	Puntos críticos de seguridad	Cobertura	Duplicaciones
camino-c	14.754	0	118	178	6	0,0%	1,0%
backend	9.052	0	57	104	1	0,0%	1,1%
Interfaz	5.702	0	61	74	5	0,0%	0,7%

Se muestran 2 de 2

camino-c/.../assets/javascripts/redmine_people.js

camino-c/.../assets/javascripts/redmine_people.js

☐ [Agregue la palabra clave "let", "const" o "var" a esta declaración de "tab" para hacerla explícita.](#) Intencionalidad
Mantenibilidad Bloqueador trampa +
Abierto No asignado L 51 • Esfuerzo de 2 minutos • Hace 33 minutos

☐ [Agregue la palabra clave "let", "const" o "var" a esta declaración de "partial" para hacerla explícita.](#) Intencionalidad
Mantenibilidad Bloqueador trampa +
Abierto No asignado L 54 • Esfuerzo de 2 minutos • Hace 33 minutos

☐ [Agregue la palabra clave "let", "const" o "var" a esta declaración de "placeholder" para hacerla explícita.](#) Intencionalidad
Mantenibilidad Bloqueador trampa +
Abierto No asignado L 55 • Esfuerzo de 2 minutos • Hace 33 minutos





☐

Define una constante en lugar de duplicar este literal "Azure AD" 3 veces.

Adaptabilidad

Mantenibilidad Alto

diseño +

Abierto No asignado

L 44 • Esfuerzo de 6 minutos • Hace 36 minutos

☐

Refactoriza este método para reducir su Complejidad Cognitiva de 16 a los 15 permitidos.

Adaptabilidad

Mantenibilidad Alto

sobrecarga cerebral arquitectura +

Abierto No asignado

L 107 • Esfuerzo de 6 minutos • Hace 36 minutos

☐

Define una constante en lugar de duplicar este literal "application/json" 4 veces.

Adaptabilidad

Mantenibilidad Alto

diseño +

Abierto No asignado

L 127 • Esfuerzo de 8 minutos • Hace 36 minutos

☐

Refactoriza este método para reducir su complejidad cognitiva de 23 a 15, el límite permitido.

Adaptabilidad

Mantenibilidad Alto

sobrecarga cerebral arquitectura +

Abierto No asignado

L 242 • Esfuerzo de 13 minutos • Hace 36 minutos



f/CundiGob x@CundinamarcaGob
www.cundinamarca.gov.co